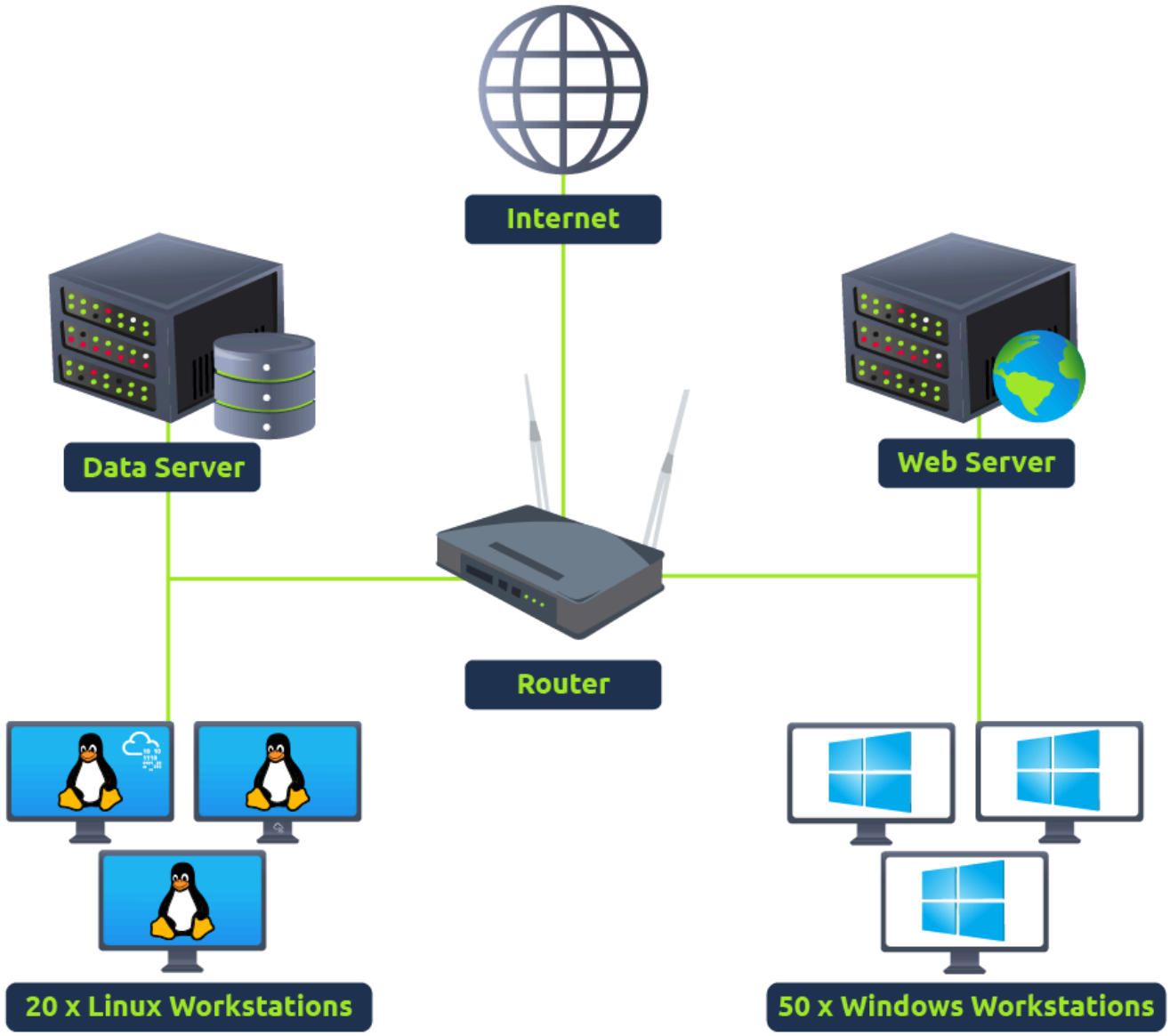
Introduction to SIEM

Security Information and Event Management system (SIEM) is the core security solution that a SOC analyst uses in the security operations centre

Logs Everywhere, Answers Nowhere



These devices continuously generate logs of the activities that occur within them. We can also call these devices log sources. The logs they generate serve as a trail of all the activities and are extremely helpful for identifying malicious activities or general troubleshooting

1) Host-Centric Log Sources

These log sources capture events that occurred within or related to the host. Devices that generate host-centric logs include Windows, Linux, servers, etc. Some examples of host-centric

logs are:

- A user accessing a file
- A user attempting to authenticate.
- A process execution activity
- A process adding/editing/deleting a registry key or value.
- PowerShell execution

2) Network-Centric Log Sources

Network-related logs are generated when the hosts communicate with each other or access the internet to visit a website. Devices that generate network-centric logs are firewalls, IDS/IPS, routers, etc. Some examples of network-centric logs are:

- SSH connection
- A file being accessed via FTP
- Web traffic
- A user accessing the company's resources through VPN.
- Network file sharing Activity

Answers Nowhere

- **Numerous Log Sources** A network has many log sources, which generate hundreds of events per second. These logs are scattered across different devices, and examining the logs on each device one by one in case of an incident can be tedious.
- **No Centralisation** As logs reside on the machines on which they are generated, you may need to connect with each log source via SSH, RDP, etc., to analyse logs from multiple log sources. This is very inefficient and can waste a lot of your valuable time during the investigations.
- **Limited Context** Individual logs cannot tell the whole story of an activity. During any incident, the individual activities on different log sources may seem harmless. But if these logs are correlated, they can indicate a whole different story.
- **Limited Analysis** The log sources generate numerous logs per second, and analysing all the logs from all the devices manually to identify any abnormal activity is nearly impossible for humans. Realistically, the analysts will miss a lot of important logs in between the analyses due to their huge number.
- **Format Issues** Different log sources generate logs in various formats. Analysts need to know all these formats to analyse them, which can be extremely difficult, especially when dealing with numerous log sources in a network.

Why SIEM ?

Features of SIEM

- **Centralised Log Collection**
  SIEM collects logs from all sources (endpoints, servers, firewalls, etc.) and centralises them in one place.
- **Normalisation of Logs**

  SIEM solution centralises these logs in one place, it also ensures that all the logs are broken down into different fields and presented in one consistent format. Breaking down a log into several fields for ease of understanding is known as Parsing, and converting all the logs of various log sources into one consistent format is known as Normalisation.

- **Correlation of Logs**
  Individual logs are not very useful. SIEM correlates the logs of different sources and finds any relationship between them. This helps to identify malicious activity by analysing its pattern.
- Real-time Alerting
  SIEM detects malicious activities based on the rules it contains. Many rules come with a SIEM by default. However, analysts make new detection rules based on their requirements to mature future detections. When the conditions for these detection rules are satisfied, alerts are triggered, and the analysts are notified. Analysts can then investigate these alerts within the SIEM platform.
- Dashboards and Reporting
  SIEM presents the data for analysis after being normalised and ingested. The summary of this analysis is presented in the form of actionable insights with the help of multiple dashboards. Each SIEM solution comes with some default dashboards and provides an option for custom Dashboard creation. Below is some of the information that can be found in a dashboard:
  - Alert Highlights
  - System Notification
  - Health Alert
  - List of Failed Login Attempts
  - Events Ingested Count
  - Rules triggered
  - Top Domains Visited

Log Sources and Ingestion

Log Sources

Every device in the network generates some kind of log whenever an activity is performed on it.

Windows Machine

Windows records every event that can be viewed through the Event Viewer. It assigns a unique ID to each type of log activity, making it easy for the analyst to examine and keep track of.

Linux Machine

Linux OS stores all the related logs, such as events, errors, warnings, etc. These are then ingested into SIEM for continuous monitoring. Some of the common locations where Linux stores logs are:

- /var/log/httpd: Contains HTTP Request / Response and error logs.

- /var/log/cron: Events related to cron jobs are stored in this location.
- /var/log/auth.log and /var/log/secure: Stores authentication-related logs.
- /var/log/kern: This file stores kernel-related events.

Web Server

It is important to monitor all requests/responses coming in and out of the web server for any potential web attack attempt. In Linux, common locations to write all apache-related logs are /var/log/apache or /var/log/httpd.

Log Ingestion

Some common methods used by these SIEM solutions are explained below:

1. Agent / Forwarder
   These SIEM solutions provide a lightweight tool called an agent (forwarder by Splunk) that gets installed on the Endpoint. It is configured to capture and send all the important logs to the SIEM server.
2. **Syslog**
   Syslog is a widely used protocol to collect data from various systems like web servers, databases, etc., and send real-time data to the centralized destination.
3. **Manual Upload**
   Some SIEM solutions, like Splunk, ELK, etc., allow users to ingest offline data for quick analysis. Once the data is ingested, it is normalised and made available for analysis.
4. **Port-Forwarding**
   SIEM solutions can also be configured to listen on a certain port, and then the endpoints forward the data to the SIEM instance on the listening port.

Alerting Process and Analysis

SIEM solution has detection rules that catch threats. These rules play an important role in the timely detection of threats, allowing analysts to take action on time.

- If a user gets five failed Login Attempts in 10 seconds, raise an alert for `Multiple Failed Login Attempts`
- If login is successful after multiple failed login attempts, raise an alert for `Successful Login After multiple Login Attempts`
- A rule is set to alert every time a user plugs in a USB (Useful if USB is restricted as per the company policy)
- If outbound traffic is > 25 MB, raise an alert to potential data exfiltration Attempt (Usually, it depends on the company policy)

How is a detection rule created?

To explain how the rule works, consider the following Eventlog use cases:

Use-Case 1:

Adversaries tend to remove the logs during the post-exploitation phase to remove their tracks. A unique Event ID **104** is logged every time a user tries to remove or clear event logs. To create a rule based on this activity, we can set the condition as follows:

Rule: If the Log source is WinEventLog **AND** EventID is **104** - Trigger an alert `Event Log Cleared`

Use-Case 2:

Adversaries use commands like `whoami` after the exploitation/privilege escalation phase. The following Fields will be helpful to include in the rule.

- Log source: Identify the log source capturing the event logs
- Event ID: Which Event ID is associated with Process Execution activity? In this case, Event ID 4688 will be helpful.
- NewProcessName: Which process name will be helpful to include in the rule?

Rule: If Log Source is WinEventLog **AND** EventCode is **4688,** and NewProcessName contains **whoami,** then Trigger an ALERT `WHOAMI command Execution DETECTED`

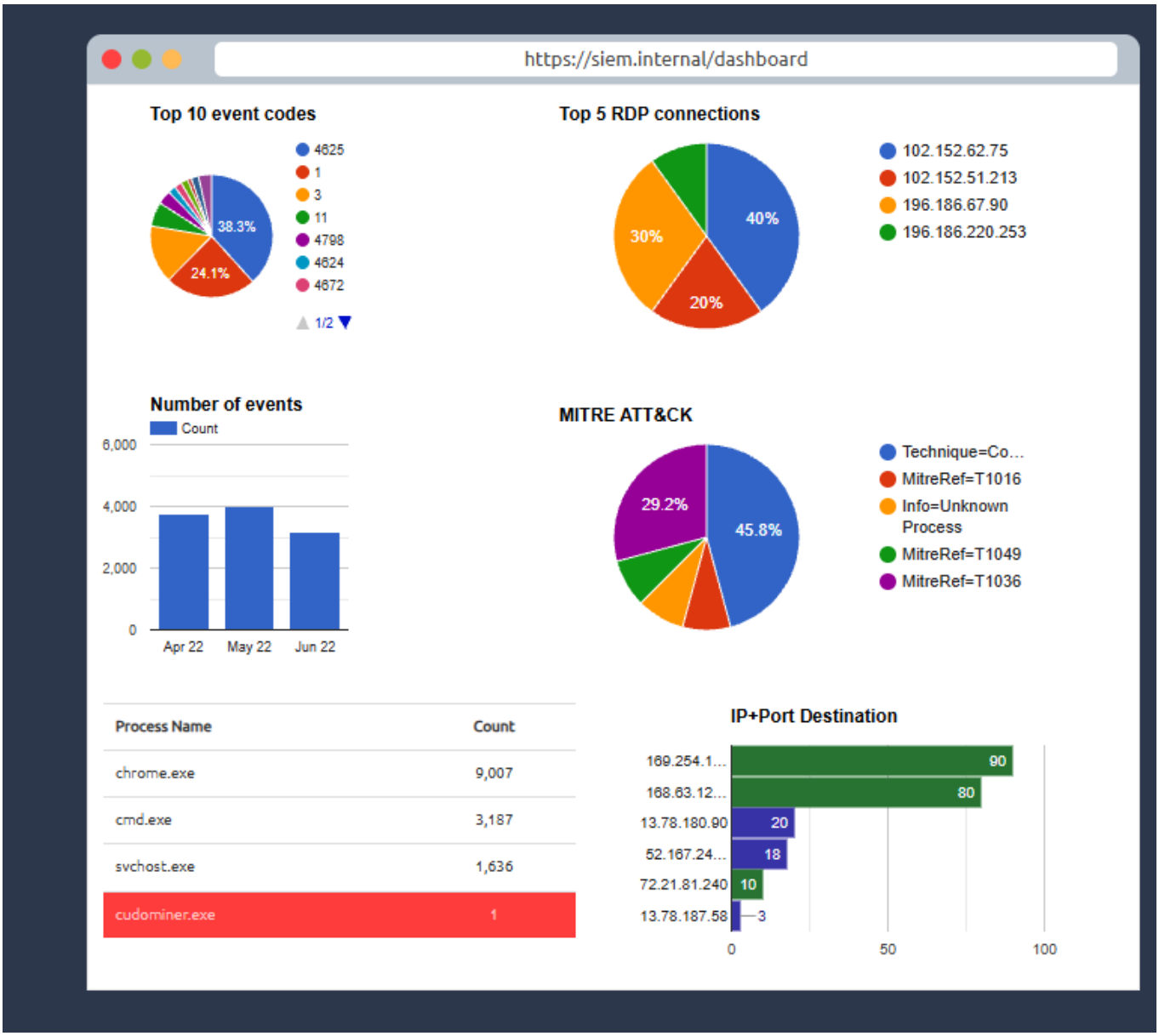
Alert Investigation

Once an alert is triggered, the events/flows associated with the alert are examined, and the rule is checked to see which conditions are met.

- Alert is a False Positive. It may require tuning the rule to avoid similar False positives from occurring again.
- Alert is a True Positive. Perform further investigation.
- Contact the asset owner to inquire about the activity.
- Suspicious activity is confirmed. Isolate the infected host.
- Block the suspicious IP.

Lab of SIEM Dashboard

cudominer.exe caused an alert



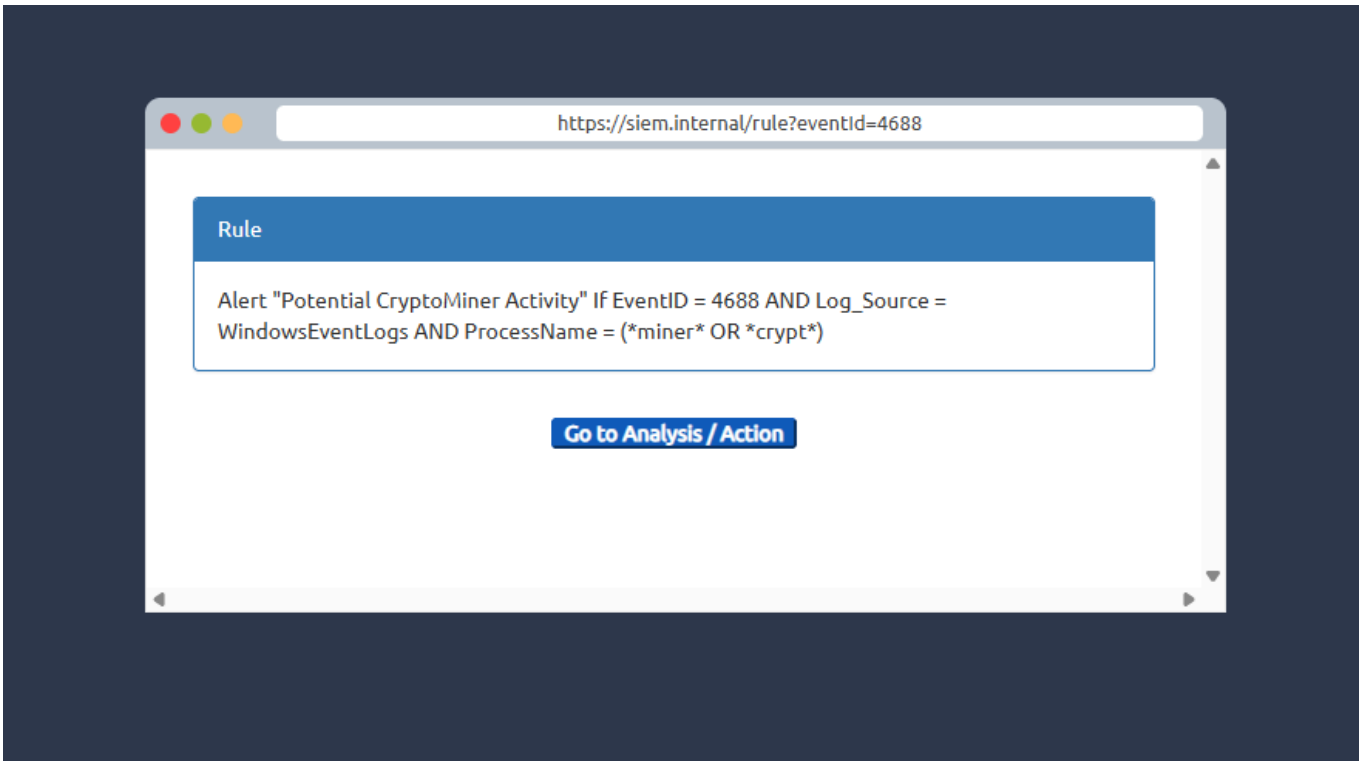
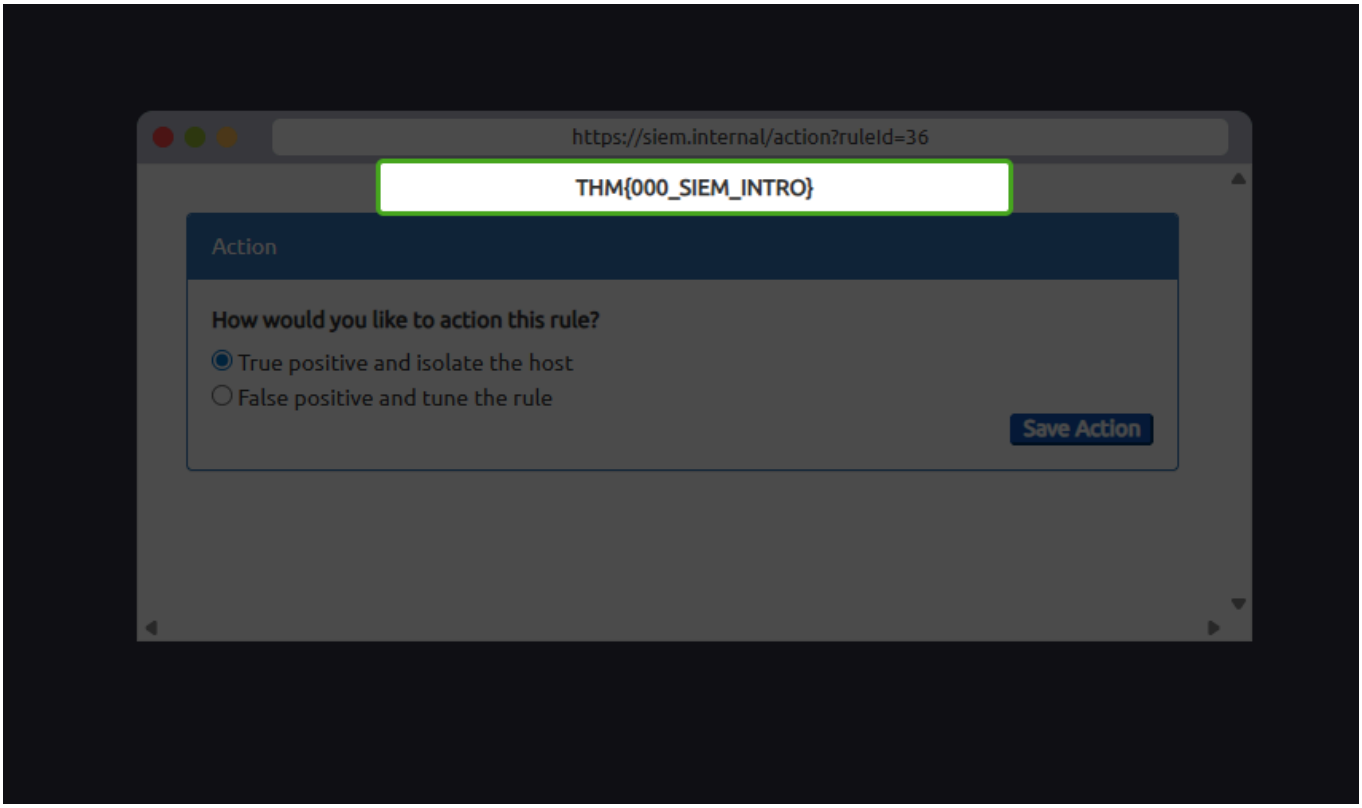
I then clicked into processes and found the event where cudominer.exe was executed

https://siem.internal/events

ModuleName	HostName	UserName	ProcessName	Opcode	SourceModule
g	HR_01	haroon	C:\Windows\System32\MicrosoftEdgeSH.exe	Info	Win_event_log
g	Admin_02	Moin	C:\Program Files (x86)\java\jre1.8.0_181\bin\javaws.exe	Info	Win_event_log
g	IT_01	Bell	C:\Python3\python.exe	Info	Win_event_log
g	HR_02	Chris	C:\Users\Chris\temp\cudominer.exe	Info	Win_event_log
g	IT_02	Amelia	C:\Program Files\QuickTime\quicktime.exe	Info	Win_event_log
g	HR_03	Daina	C:\Program Files\Quicken\qw.exe	Info	Win_event_log

here I can find the process execution, the user responsible for executing this file and the hostname of the suspected user

it then showed me the rule that detected this and alerted me due to the process name containing "miner"



Next I had to select if it was a true positive or a false positive. I actioned the rule as this file contained the word miner and was alerted. then it gave me the flag